요구사항 명세서(SRS) 초안

논문-10: AES + IBE 하이브리드 이미지 암호화(Encra) -> 금융보안

Hybrid Image Encryption Framework (Encra) - Financial Security Application

1. 문서 정보

문서명	[프로젝트명] 요구사항 명세서(SRS)
버전	v0.1
작성일	2026-04-04
작성자	[이름]
대상	논리 설계 + 시뮬레이션 기반 평가

2. 용어/약어

용어/약어	설명
AES	Advanced Encryption Standard - 대칭키 블록 암호 (빠른 속도, 대용량 데이터 적합)
IBE	Identity-Based Encryption - 아이덴티티 기반 암호화 (공개키 인프라 없이 ID를 공개키로 사용)
Encra	AES + IBE 하이브리드 이미지 암호화 프레임워크 (논문 10 제안 시스템)
KYC	Know Your Customer - 금융기관 고객 신원확인 의무 절차
eKYC	Electronic KYC - 비대면 디지털 신원확인 (얼굴사진 및 신분증 이미지 활용)
PII	Personally Identifiable Information - 개인 식별 정보
PKG	Private Key Generator - IBE 마스터 키 보유 기관, 개인키 발급 주체
MITM	Man-in-the-Middle - 중간자 공격
Hash	SHA-256 등 해시함수 - 무결성 검증에 활용
FDS	Fraud Detection System - 이상금융거래탐지시스템

MFA	Multi-Factor Authentication - 다중인증
OTP	One-Time Password - 일회용 비밀번호

3. 목표 및 성공 기준

3.1 목표

- AES + IBE 하이브리드 암호화(Encra)를 금융 서비스 이미지 데이터(신분증, 얼굴, 보험청구 사진)에 적용해 기밀성과 무결성을 보장한다.
- 비대면 eKYC 이미지 전송 시 도청, 위변조, 피싱 공격을 방어하고 수신자(금융기관) 외 제 3 자 복호화를 불가능하게 한다.
- IBE 키 관리 구조로 PKI 없이 금융 고객 ID 기반 암호화를 지원해 모바일뱅킹 및 보험청구 채널에 실용적으로 적용한다.

3.2 성공 기준

- Encra 암호화/복호화 처리 시간: 5MB 이미지 기준 순수 IBE 단독 대비 50% 이상 단축
- 이미지 무결성 검증(Hash): 복호화 후 원본 일치율 99.99% 이상
- eKYC 채널 MITM 공격 시나리오: 복호화 성공률 0%
- 보험청구 이미지 위변조 탐지율: 99% 이상

4. 범위

4.1 포함

- AES 대칭키 생성 및 이미지 암호화
- IBE 공개키(수신자 금융기관 ID 기반)로 AES 키 암호화(키 캡슐화)
- 복호화: IBE 개인키로 AES 키 복원 후 이미지 복호화
- SHA-256 기반 이미지 무결성 검증
- 금융 적용: eKYC(비대면 신원확인), 모바일뱅킹 신분증 업로드, 보험청구 사진 제출
- 피싱 방어: 출처 불명 이미지 링크 및 위장 공격 탐지

4.2 제외

- 영상(Video) 스트리밍 실시간 암호화
- 이미지 내 스테가노그래피 은닉 콘텐츠 탐지
- 블록체인 기반 이미지 저장 아키텍처(저장 레이어 설계 제외)

5. 시스템 개요

5.1 구성 요소

- 사용자(금융 고객): 이미지 생성 및 업로드 주체(모바일 앱 또는 웹)
- Encra 클라이언트: AES 키 생성 및 IBE 암호화 수행 모듈
- PKG(Private Key Generator): IBE 마스터 키 보유, 금융기관 ID 기반 개인키 발급
- 금융기관 서버: IBE 개인키로 AES 키 복원 후 이미지 복호화 및 eKYC/보험심사 처리
- Hash 검증 모듈: 암호화 전 원본 해시와 복호화 후 해시를 비교해 위변조 판정

5.2 운영 흐름

- 고객이 신분증/보험청구 사진 촬영 -> 앱이 AES 키 생성 -> 이미지 AES 암호화
- AES 키를 금융기관 ID(이메일/기관코드)로 IBE 암호화 -> 암호화 이미지 + 캡슐화된 키 전송
- 금융기관이 IBE 개인키로 AES 키 복원 -> 이미지 복호화 -> Hash 무결성 검증 -> eKYC/보험심사 처리

6. 우선순위 규칙

우선순위	레벨	의미
P0	Must	반드시 구현되어야 하는 핵심 요구사항
P1	Should	구현이 강력히 권장되는 요구사항
P2	Could	자원이 허용되는 경우 구현 가능한 요구사항

7. 기능 요구사항(FR)

FR-01 AES + IBE 하이브리드 암호화(이미지 암호화) [P0]

설명	금융 이미지(신분증/얼굴/보험청구 사진)를 AES로 암호화하고, AES 키를 수신자(금융기관) ID 기반 IBE 공개키로 캡슐화한다.
근거	AES 단독은 키 배포 문제, IBE 단독은 대용량 이미지 암호화 속도 저하. 하이브리드 방식으로 두 한계를 동시 해결.
입력	평문 이미지(JPEG/PNG), 수신자 금융기관 ID
처리	AES 키 생성 -> 이미지 AES 암호화 -> AES 키 IBE 암호화(키 캡슐화)
출력	암호화 이미지 파일 + IBE 캡슐화 AES 키
예외	키 생성 실패 또는 IBE 공개키 미확인 시 암호화 중단 후 오류 반환
검증	복호화 후 원본 이미지와 Hash 비교, 일치 여부 검증

FR-02 IBE 키 관리 및 PKG 인터페이스 [P0]	
설명	PKG(Private Key Generator)가 금융기관 ID(기관코드/이메일)를 공개키로 사용하는 IBE 개인키를 발급하고 안전하게 배포한다.
근거	PKI 없이 ID = 공개키 구조로 금융기관별 별도 인증서 관리 없이 암호화 가능. 키 관리 인프라 비용 절감.
입력	금융기관 ID, PKG 마스터 키
처리	IBE 키 생성(Setup/Extract) 실행, 개인키 TLS 채널을 통해 금융기관에 전달
출력	금융기관 IBE 개인키(안전 채널 전달)
예외	ID 미등록 또는 PKG 인증 실패 시 키 미발급 및 감사 로그 기록
검증	발급된 개인키로 테스트 암호문 복호화 성공 여부 검증

FR-03 이미지 무결성 검증(Hash 기반) [P0]	
설명	암호화 전 원본 이미지의 SHA-256 Hash를 생성해 메타데이터에 첨부하고, 복호화 후 재계산 Hash와 비교해 위변조 여부를 판정한다.
근거	eKYC 이미지 위변조는 금융 사기(신원도용/허위보험청구)로 직결. Hash 검증으로 전송 중 조작 탐지가 필수.
입력	암호화 이미지 + Hash 메타데이터
처리	복호화 후 이미지 Hash 재계산 -> 원본 Hash와 비교

출력	검증 결과(PASS/FAIL) + 위변조 여부 플래그
예외	Hash 불일치 시 이미지 폐기 및 경고 알림, 의심거래 FDS 연계
검증	1비트 수정 이미지로 Hash 불일치 탐지율 100% 테스트

FR-04 eKYC 비대면 신원확인 채널 보안 [P1]	
설명	모바일뱅킹/인터넷뱅킹 비대면 계좌개설/대출신청 시 신분증 이미지 전송을 Encra로 보호해 도청 및 MITM 공격을 방어한다.
근거	전자금융감독규정상 비대면 실명확인 시 이미지 보안 의무. 일반 TLS만으로는 서버 측 내부자 위협 방어 불가.
입력	고객 신분증 촬영 이미지, 금융기관 eKYC 서버 ID
처리	Encra 암호화 -> 금융기관 IBE 개인키 복호화 -> Hash 무결성 검증 -> 실명확인 처리
출력	실명확인 결과(성공/실패), 복호화된 신분증 정보(금융기관 내부 처리용)
예외	이미지 용량 초과(10MB 이상) 또는 지원 형식 외 파일 업로드 시 오류 반환
검증	MITM 공격 시나리오에서 복호화 성공률 0% 검증

FR-05 보험청구 사진 위변조 방어 [P1]	
설명	보험청구 시 제출하는 사고/의료 사진을 Encra + Hash로 보호하여 청구 이미지의 위변조 및 Replay 공격을 탐지하고 차단한다.
근거	허위 보험청구 이미지 조작은 보험사기의 핵심 수단. 이미지 암호화 + Hash로 접수부터 심사까지 무결성 보장 필요.
입력	사고/의료 사진, 청구 ID, 타임스탬프
처리	이미지 암호화 + 타임스탬프/청구 ID Hash 생성 -> 보험사 서버 복호화 및 검증
출력	청구 이미지 무결성 검증 결과, 재사용 여부 플래그
예외	타임스탬프 불일치 또는 Hash 재사용 탐지 시 FDS 경보 발송
검증	동일 이미지 재사용(Replay) 공격 탐지율 99% 이상 검증

FR-06 피싱 이미지 탐지 및 차단 [P2]	
설명	금융 앱 내 출처 불명 이미지 링크를 통한 피싱 공격 시, 수신 이미지에 Encra 암호화 + 기관 Hash 서명이 없으면 표시 전 차단한다.
근거	피싱은 가짜 이미지(위장 송금화면/OTP 캡처 요구)로 고객을 속이는 주요 금융사기. 이미지 출처 검증이 방어 핵심.
입력	수신 이미지 + 출처 메타데이터
처리	이미지 출처/서명 검증 -> 미서명 이미지 차단 -> 의심 이미지 FDS 리포트
출력	차단 여부 결과, 의심 피싱 리포트
예외	정상 이미지 오탐 시 사용자 수동 확인 절차 제공
검증	피싱 시뮬레이션 이미지 차단율 95% 이상 검증

8. 비기능 요구사항(NFR)

NFR-01 성능 - AES+IBE 하이브리드 처리 속도 [P0]	
설명	Encra 암호화(AES 이미지 암호화 + IBE 키 캡슐화) 전체 처리 시간: 5MB 이미지 기준 300ms 이하(모바일 기기 기준)
근거	eKYC 비대면 채널에서 고객 체감 지연 최소화 필요. IBE 단독 적용 시 수 초 소요되는 대용량 암호화를 AES 병렬화로 해결.
검증	처리 시간 벤치마크(5MB JPEG, 다양한 해상도), 100회 반복 평균

NFR-02 보안 - IBE 기반 종단간 이미지 기밀성 [P0]	
설명	수신자(금융기관) IBE 개인키 없이는 AES 키 복원 불가, 이미지 기밀성 수학적 보장. IND-CPA 안전성 요건 충족.
근거	금융 이미지에는 PII(주민번호/얼굴/의료정보) 포함. 내부자 포함 제3자 접근 원천 차단 필수.
검증	IND-CPA 공격 시나리오 검증, 개인키 없는 복호화 시도 성공률 0% 확인

NFR-03 규제 준수 - 전자금융 및 개인정보 보호 [P1]

설명	전자금융거래법, 개인정보 보호법(민감정보 암호화 의무), 금융위 비대면 실명확인 지침 준수. 이미지 보관 시 AES-256 암호화 및 접근 제어 적용.
근거	금융기관은 법적 의무로 고객 이미지 데이터 암호화 보관 및 접근 이력 관리 필요.
검증	규제 체크리스트 점검, 감사 로그 기록 완전성 검증

NFR-04 확장성 - 다중 금융기관 멀티테넌트 [P2]	
설명	단일 PKG 인프라에서 다수의 금융기관 ID(은행/보험/증권사)를 동시 지원. 기관별 IBE 개인키 독립 관리 및 격리 보장.
근거	금융 생태계는 다수 기관 참여 구조. 기관별 독립 키 관리로 한 기관 침해 시 타 기관 영향 차단.
검증	10개 기관 동시 키 발급/암호화 처리 부하 테스트

9. 가정 및 제약

9.1 가정

- PKG 는 신뢰 가능한 제 3 자(금융결제원 등)가 운영하며 마스터 키가 안전하게 보관된다.
- 금융 고객 단말(모바일)에 Encra 클라이언트 앱이 설치되어 있다.
- 금융기관은 PKG 로부터 사전에 IBE 개인키를 발급받아 보관하고 있다.

9.2 제약

- IBE 마스터 키 유출 시 전체 시스템 보안 붕괴 - 정기적 키 갱신 및 HSM 보관 필수
- 대용량 RAW 이미지(50MB 초과) 처리는 서버 측 오프로딩 아키텍처로 별도 설계 필요
- 오프라인 환경에서는 PKG 키 발급 불가 - 사전 키 캐싱 정책 필요

10. 검증 계획

10.1 단위 테스트

- FR-01: 다양한 이미지 크기(1MB, 5MB, 10MB)에 대한 Encra 암호화/복호화 왕복 정확도 100%
- FR-03: 1 비트 조작 이미지의 Hash 불일치 탐지율 100%

10.2 통합 테스트

- FR-04: 모바일 -> 금융기관 서버 eKYC 이미지 전송 시뮬레이션(MITM 공격 차단 확인)
- FR-05: 보험청구 이미지 Replay 공격 탐지 시나리오 테스트

10.3 성능 테스트

- NFR-01: 5MB 이미지 100 회 암호화 평균 처리 시간 300ms 이하
- NFR-04: 10 개 금융기관 동시 키 발급/암호화 처리 부하 테스트

부록 A. 자료조사 요약(요구사항 근거)

FR-01 근거	Encra의 AES+IBE 하이브리드 구조는 대용량 이미지 암호화 속도와 키 배포 편의성을 동시에 충족하여 eKYC 및 보험청구 채널에 직접 적용 가능
FR-03 근거	금융 이미지 위변조(신원도용/허위보험청구)는 실제 금융사기 사례에서 빈번히 활용 - Hash 기반 무결성 검증이 탐지의 핵심 수단
NFR-02 근거	IBE의 IND-CPA 안전성은 수신자 외 복호화 불가를 수학적으로 보장 - PII 포함 금융 이미지 기밀성 요건 충족
NFR-03 근거	전자금융거래법/개인정보 보호법은 고객 이미지 데이터 암호화 보관 의무 명시 - Encra는 법적 요건을 기술적으로 이행하는 수단